COM/BLM 426
BİLGİ GÜVENLİĞİ

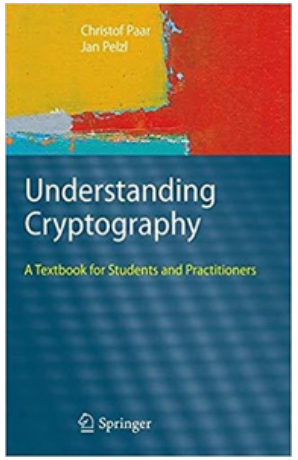
Asst. Prof. Dr. Bulent TUGRUL
btugrul@eng.ankara.edu.tr

Slides are mainly based on:

Understanding Cryptography: A Textbook for Students and Practitioners

by ChristofPaarand Jan Pelzl

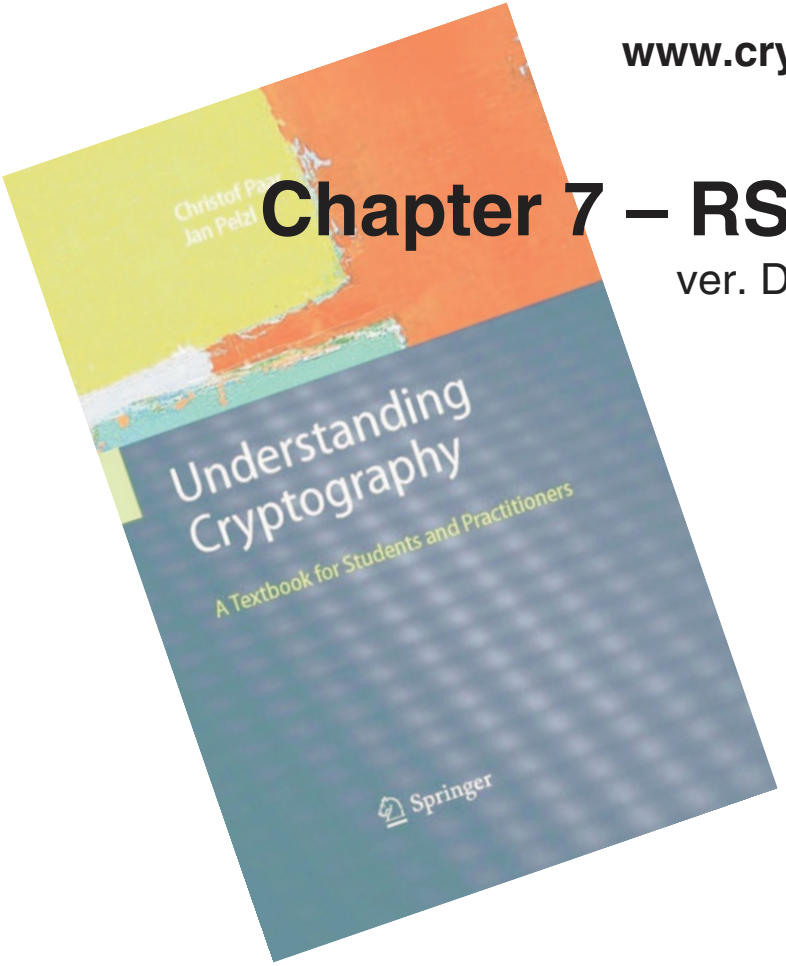
Springer, 1st Edition, 2010



Understanding Cryptography –A Textbook for Students and Practitioners

by Christof Paar and Jan Pelzl

www.crypto-textbook.com



Chapter 7 – RSA Kriptosistemi

ver. December 7, 2010

These slides were prepared by Benedikt Driessen, Christof Paar and Jan Pelzl

Bazı yasal bilgiler (sorry): Kullanım Şartları

- Slaytlar ücretsiz olarak kullanılabilir. Slaytların tüm telif hakları Christof Paar ve Jan Pelzl'e aittir.

- Eşlik eden "Understanding Cryptography" kitabının başlığı (Springer tarafından) ve yazarların isimleri her slaytta yer almalıdır.

- Slaytlar değiştirilirse, kitap yazarlarına ve kitap başlığına ilişkin uygun atıflar slaytlarda yer almalıdır.

- Yazarların yazılı izni olmadan slaytların tamamının veya bir kısmının basılı olarak çoğaltılmasına izin verilmez.

Bu Bölümün İçeriği

- RSA Kriptosistemi
- Uygulama yönleri
- Büyük Asal Sayıları Bulma
- Saldırılar ve Karşı Önlemler
- Öğrenilen Dersler

Bu Bölümün İçeriği

- **RSA Kriptosistemi**
- Uygulama yönleri
- Büyük Asal Sayıları Bulma
- Saldırılar ve Karşı Önlemler
- Öğrenilen Dersler

RSA Kriptosistemi

- Martin Hellman ve Whitfield Diffie, çığır açan "public-key" makalelerini 1976'da yayınladılar.
- Ronald Rivest, Adi Shamir ve Leonard Adleman, 1977'de asimetrik RSA şifreleme sistemini önerdiler.
- Şu ana kadar RSA, en yaygın kullanılan asimetrik şifreleme sistemidir, ancak eliptik eğri şifrelemesi (ECC) giderek daha popüler hale gelmektedir.
- RSA esas olarak iki uygulama için kullanılır:
  - (Simetrik) anahtarların taşınması (Understanding Cryptography kitabının 13. Bölümüne bakınız)
  - Dijital imzalar (Understanding Cryptography kitabının 10. Bölümüne bakınız)

Şifreleme ve Şifre Çözme

- RSA işlemleri, n = p * q olmak üzere, p ve q'nun büyük asal sayılar olduğu tamsayı halkası Z_n *(yani aritmetik modül n) üzerinde yapılır.*
- Şifreleme ve şifre çözme, halkada basitçe üs alma işlemleridir.

Tanım

Verilen açık anahtar $\boldsymbol{(n,e) = k_{pub}}$ *ve özel anahtar* $\boldsymbol{d = k_{pr}}$ *'yi şu şekilde yazabiliriz:*

$$y = e_{k_{pub}}(x) \equiv x^e \bmod n$$

$$x = d_{k_{pr}}(y) \equiv y^d \bmod n$$

burada x, y ε Z_n.

Şifreleme işlemine $e_{kpub}()$ şifre çözme işlemine ise $d_{kpr}()$ adını veriyoruz.

- Pratikte x, y, n ve d çok uzun tamsayı sayılardır (≥ 1024 bit).
- Sistemin güvenliği, açık anahtar (n, e) verildiğinde "özel üs" d'nin türetilmesinin zor olmasına dayanmaktadır.

Anahtar Üretimi

- Tüm asimetrik şemalar gibi, RSA'nın da özel ve açık anahtarların hesaplandığı bir kurulum aşaması vardır.

Algoritma: RSA Anahtar Üretimi

Çıktı: Açık anahtar: $k_{pub} = (n, e)$ *ve özel anahtar* $k_{pr} = d$

1. İki büyük asal sayı seçin p, q
2. Hesapla $n = p * q$
3. Hesapla $\Phi(n) = (p - 1) * (q - 1)$
4. gcd $(e, \Phi(n)) = 1$ *olacak şekilde Genel üs* $e \varepsilon \{1, 2, \ldots, \Phi(n) - 1\}$ *'i seçin.*
5. $d * e \equiv 1 \bmod \Phi(n)$ *olacak şekilde özel anahtar d'yi hesaplayın.*
6. **RETURN** $k_{pub} = (n, e), k_{pr} = d$

Notlar:

- (1. adımda) birbirinden farklı iki büyük asal sayı p ve q seçmek önemsiz bir işlem değildir.
- **gcd**$(e, \Phi(n)) = 1$, *e'nin bir tersinin olduğunu ve dolayısıyla her zaman bir özel anahtar d'nin var olduğunu garanti eder.*

Örnek: Küçük sayılarla RSA

ALICE

Mesaj $x = 4$

BOB

1. $p = 3$ ve $q = 11$ seçin
2. $n = p * q = 33$ hesaplayın
3. $\Phi(n) = (3-1) * (11-1) = 20$
4. $e = 3$ seçin
5. $d \equiv e^{-1} \equiv 7 \bmod 20$

$K_{pub} = (33,3)$ ←

$y = x^e \equiv 4^3 \equiv 31 \bmod 33$

$y = 31$ →

$y^d = 31^7 \equiv 4 = x \bmod 33$

Bu Bölümün İçeriği

- RSA Kriptosistemi
- **Uygulama yönleri**
- Büyük Asal Sayıları Bulma
- Saldırılar ve Karşı Önlemler
- Öğrenilen Dersler

Uygulama yönleri

- RSA şifreleme sistemi yalnızca tek bir aritmetik işlem (modüler üs alma) kullanır, bu da onu kavramsal olarak basit bir asimetrik şema yapar.
- Kavramsal olarak basit olmasına rağmen, çok uzun sayılar kullanılması nedeniyle RSA, DES, AES gibi simetrik şemalardan kat kat daha yavaştır.
- RSA'yı uygularken (özellikle akıllı kartlar veya cep telefonları gibi kısıtlı bir cihazda) doğru aritmetik algoritmaların seçimine çok dikkat edilmelidir.
- Kare alma ve çarpma algoritması, çok uzun sayılarla bile hızlı üs alma sağlar…

Kare ve Çarpma

- **Temel prensip:** Üslü bitleri soldan sağa tarayın ve buna göre işleneni karesini alın/çarpın.

Algoritma: x^H mod n için Kare Alma ve Çarpma

Girdi: Üs H, taban elemanı x, Modül n

Çıktı: $y = x^H \bmod n$

1. İkili gösterimi belirleyin $H = (h_t, h_{t-1}, ..., h_0)_2$
2. **FOR** $i = t-1$ **TO** 0
3. $y = y^2 \bmod n$
4. **IF** $h_i = 1$ **THEN**
5. $y = y * x \bmod n$
6. **RETURN** y

- Kural: Her yinelemede karesini alın (Adım 3) ve üs biti $h_i = 1$ *ise mevcut sonucu x ile çarpın (Adım 5).*
- Her adımdan sonra modül indirgeme işlemi, işlenen y'yi küçük tutar.

Örnek: Kare ve Çarpma

- Modül indirgemesi olmadan x^{26} *'yı hesaplar.*
- Üssün ikili gösterimi: $26 = (1,1,0,1,0)_2 = (h_4,h_3,h_2,h_1,h_0)_2$

Adım		İkili üs	İşlem	Yorum
1	$x = x^1$	$(1)_2$		h_4
1a	$(x^1)^2 = x^2$	$(10)_2$	SQ	h_3
1b	$x^2 * x = x^3$	$(11)_2$	MUL	$h_3 = 1$
2a	$(x^3)^2 = x^6$	$(110)_2$	SQ	h_2
2b	-	$(110)_2$	-	$h_0 = 0$
3a	$(x^6)^2 = x^{12}$	$(1100)_2$	SQ	h_1
3b	$x^{12} * x = x^{13}$	$(1101)_2$	MUL	$h_1=1$
4a	$(x^{13})^2 = x^{26}$	$(11010)_2$	SQ	h_0
4b	-	$(11010)_2$	-	$h_0 = 0$

- Üssün $x^{26} = x^{11010}$ *şekline nasıl dönüştüğünü gözlemleyin.*

Kare alma ve çarpma algoritmasının karmaşıklığı.

- Kare alma ve çarpma algoritmasının logaritmik bir karmaşıklığı vardır, yani çalışma süresi üssün mutlak değerinden ziyade bit uzunluğuyla orantılıdır.
- **t+1** bitlik bir üs verildiğinde

  $H = (h_t, h_{t-1}, \ldots, h_0)_2$

  $h_t = 1$, olduğunda, aşağıdaki işlemlere ihtiyacımız var:

  - *# Kare alma sayısı* $= t$
  - Ortalama # çarpımlar $= 0.5\ t$
  - Toplam karmaşıklık: *#SQ + #MUL* $= 1.5\ t$
- Üsler genellikle rastgele seçilir, bu nedenle **1,5 t**, ortalama işlem sayısı için iyi bir tahmindir.
- Her kare alma ve her çarpma işleminin çok uzun sayılarla, örneğin 2048 bitlik tamsayılarla yapılan bir işlem olduğunu unutmayın.

Hızlandırma Teknikleri

- Modüler üs alma işlemi yoğun hesaplama gerektirir.
- Kare alma ve çarpma algoritması kullanılsa bile, RSA, akıllı kartlar gibi kısıtlı cihazlarda oldukça yavaş olabilir.
- Bazı önemli püf noktaları:
    - Kısa açık üs e
    - Çin Kalan Teoremi (ÇKT)
    - Ön hesaplamalı üs alma (burada ele alınmamıştır)

Küçük genel üs ile hızlı şifreleme

- Küçük bir genel üs e seçmek, RSA'nın güvenliğini zayıflatmaz.
- Küçük bir genel üs, RSA şifrelemesinin hızını önemli ölçüde artırır.

Açık Anahtar	e ikili dize olarak	**#MUL + #SQ**
$2^1+1 = 3$	$(11)_2$	1 + 1 = 2
$2^4+1 = 17$	$(1\ 0001)_2$	4 + 1 = 5
$2^{16} + 1$	$(1\ 0000\ 0000\ 0000\ 0001)_2$	16 + 1 = 17

- Bu, yaygın olarak kullanılan bir yöntemdir (örneğin, SSL/TLS, vb.) ve RSA'yı şifreleme açısından en hızlı asimetrik şema haline getirir!

CRT ile hızlı şifre çözme

- Küçük bir özel anahtar d seçmek güvenlik zafiyetlerine yol açar!
  - Aslında, d'nin en az 0,3t bit uzunluğunda olması gerekir; burada t, modülün bit uzunluğu n'dir.
- Ancak, Çin Kalan Teoremi (ÇKT), özel anahtar d ile üs alma işlemini (biraz da olsa) hızlandırmak için kullanılabilir.
- CRT'ye dayanarak, aşağıdaki hesaplamayı değiştirebiliriz:

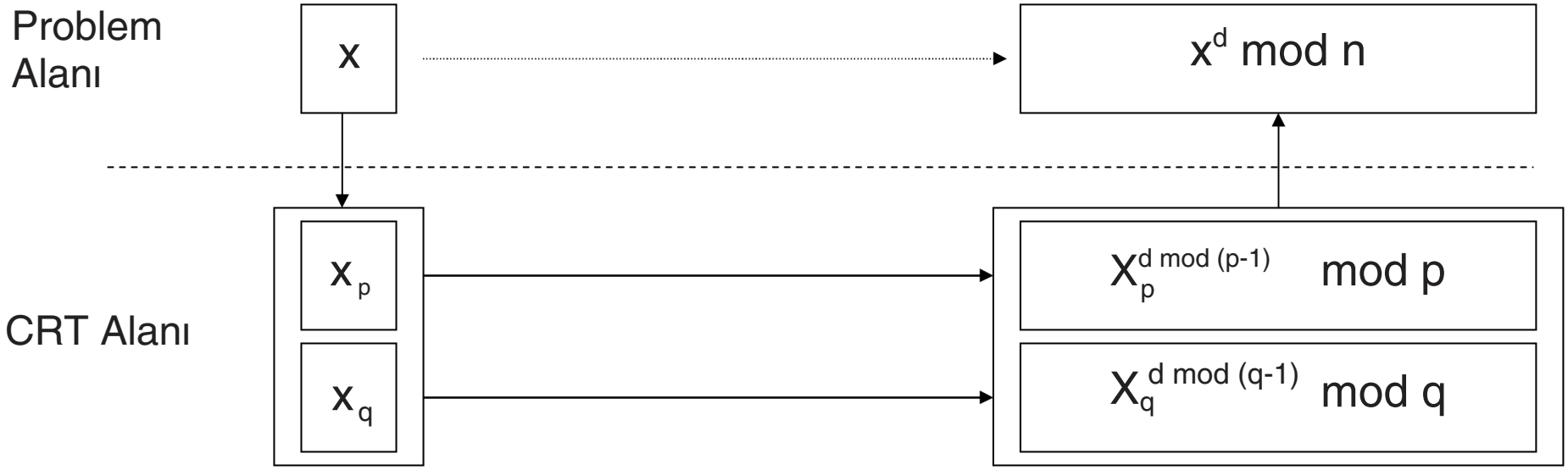
$$x^{d \bmod \Phi(n)} \bmod n$$

iki hesaplama ile

$$x^{d \bmod (p-1)} \bmod p \quad \text{and} \quad x^{d \bmod (q-1)} \bmod q$$

burada q ve p, n'ye kıyasla "küçük"tür.

CRT tabanlı üs alma işleminin temel prensibi



- CRT üç ayrı adımdan oluşur:

  (1) İşlemcinin CRT alanına dönüştürülmesi

  (2) CRT alanında modüler üs alma

  (3) Problem alanına ters dönüşüm
- Bu adımlar, problem alanında bir modüler üs alma işlemine eşdeğerdir.

CRT: Adım 1 – Dönüşüm

- CRT alanına dönüşüm, p ve q'nun bilinmesini gerektirir.
- *p ve q yalnızca özel anahtarın sahibi tarafından bilindiğinden, CRT şifrelemeyi hızlandırmak için uygulanamaz.*
- Dönüşüm, x'in CRT alanındaki temsili olan *(x_p , x_q) 'yu hesaplar. Bunlar hesaplanarak kolayca bulunabilir.*

$$x_p \equiv x \bmod p \quad \text{ve} \quad x_q \equiv x \bmod q$$

CRT: Adım 2 – Üs Alma

- Verilen $\boldsymbol{d_p}$ *ve* $\boldsymbol{d_q}$ *değerleri için*

  $$d_p \equiv d \bmod (p-1) \quad \text{ve} \quad d_q \equiv d \bmod (q-1)$$

  Problem alanında bir üs alma işlemi, CRT alanında iki üs alma işlemi gerektirir.

  $$y_p \equiv x_p^{d_p} \bmod p \quad \text{ve} \quad y_q \equiv x_q^{d_q} \bmod q$$

- Pratikte, p ve q, n'nin bit uzunluğunun yarısı olacak şekilde seçilir, yani, $|p| \approx |q| \approx |n|/2$.

CRT: Adım 3 – Ters Dönüşüm

- Ters dönüşüm, modüler ters alma işleminin iki kez yapılmasını gerektirir ki bu da hesaplama açısından maliyetlidir.

$$c_p \equiv q^{-1} \bmod p \quad \text{ve} \quad c_q \equiv p^{-1} \bmod q$$

- Ters dönüşüm, problem alanında y_p , y_q *'yu nihai sonuç olan y mod n 'ye dönüştürür.*

$$y \equiv [\, q * c_p \,] * y_p + [\, p * c_q \,] * y_q \bmod n$$

- p ve q asal sayıları genellikle nadiren değişir, bu nedenle ters alma maliyeti ihmal edilebilir çünkü iki ifade de aynıdır.

$$[\, q * c_p \,] \quad \textit{ve} \quad [\, p * c_q \,]$$

önceden hesaplanabilir ve saklanabilir

CRT'nin Karmaşıklığı

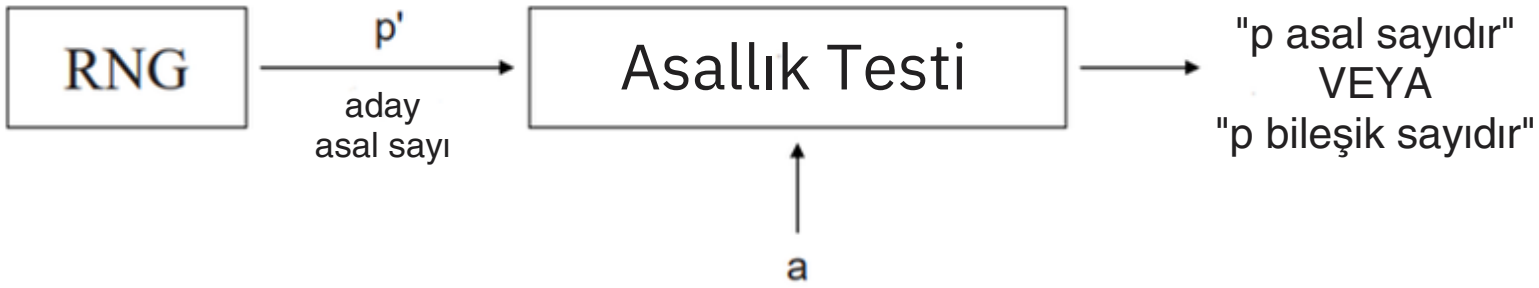
- Dönüşüm ve ters dönüşüm adımlarını göz ardı ediyoruz çünkü bu adımların maliyetleri makul varsayımlar altında ihmal edilebilir.
- n'nin t+1 bit uzunluğunda olduğunu varsayarsak, hem p hem de q yaklaşık t/2 bit uzunluğundadır.
- Karmaşıklık, CRT alanındaki iki üs alma işlemiyle belirlenir. İşlenenler yalnızca t/2 bit uzunluğundadır. Üs alma işlemleri için kare alma ve çarpma algoritmasını kullanıyoruz:
  - # Kare alma işlemleri (tek bir ifade): ***#SQ = 0.5 t***
  - # Ortalama çarpma işlemleri (tek bir ifade): **#MUL = 0.25t**
  - Toplam karmaşıklık: ***2 * (#MUL + #SQ) = 1.5t***
- Bu, normal üs alma işlemine benziyor, ancak işlenenlerin bit uzunluğu normal üs alma işlemine göre yarı yarıya daha kısa olduğundan, her işlem (yani çarpma ve kare alma) 4 kat daha hızlı gerçekleşiyor!
- Dolayısıyla CRT, doğrudan üs alma işleminden 4 kat daha hızlıdır.

Bu Bölümün İçeriği

- RSA Kriptosistemi
- Uygulama yönleri
- **Büyük Asal Sayıları Bulma**
- Saldırılar ve Karşı Önlemler
- Öğrenilen Dersler

Büyük Asal Sayıları Bulmak

- RSA için anahtarlar oluşturmak, n = p * q'nun yeterince büyük olmasını sağlayacak iki büyük asal sayı p ve q bulmayı gerektirir.
- p ve q'nun boyutu genellikle istenen n boyutunun yarısı kadardır
- Asal sayıları bulmak için rastgele tamsayılar üretilir ve asal olup olmadıkları test edilir:



- Rastgele sayı üreteci (RNG) tahmin edilemez olmalıdır, aksi takdirde bir saldırgan n'nin çarpanlarına ayrılmasını tahmin edebilir.

Asallık Testleri

- p ve q'nun asal sayı olup olmadığını test etmek için çarpanlarına ayırmak genellikle mümkün değildir.
- Ancak biz çarpanlara ayırma işlemiyle ilgilenmiyoruz, sadece p ve q'nun bileşik sayı olup olmadığını bilmek istiyoruz.
- Tipik asal sayı testleri olasılıksaldır, yani %100 doğru değildirler ancak sonuçlarının doğru olma olasılığı çok yüksektir.
- Olasılıksal bir testin iki çıktısı vardır:
    - "p bileşiktir" – her zaman doğrudur
    - "p bir asal sayıdır" ifadesi yalnızca belirli bir olasılıkla doğrudur
- Tanınmış asal sayı testleri arasında şunlar yer almaktadır:
    - Fermat Asallık Testi
    - Miller - Rabin Asallık Testi

Fermat Asallık Testi

- Temel fikir: Fermat'ın Küçük Teoremi tüm asal sayılar için geçerlidir, yani $a^{p'-1} \not\equiv 1 \bmod p'$, koşulunu sağlayan bir p' sayısı bulunursa, bu sayı asal sayı değildir.

Algoritma: Fermat Asallık Testi

Girdi: Asal aday p', güvenlik parametresi s

Çıktı: "p' bileşiktir" veya "p' muhtemelen asaldır"

1. **FOR** $i = 1$ **TO** s
2. rastgele seç $a \in \{2,3, ..., p'-2\}$
3. **IF** $a^{p'-1} \equiv 1 \bmod p'$ **THEN**
4. **RETURN** „*p' bileşiktir*"
5. **RETURN** „*p' büyük olasılıkla asal sayıdır*"

- Bazı sayılar ("Carchimchael sayıları") için bu test, bu sayılar bileşik sayılar olmasına rağmen, sıklıkla "p'nin asal sayı olma olasılığı yüksektir" sonucunu verir.
- Bu nedenle Miller-Rabin testi tercih edilir.

Miller-Rabin testi için teorem

- Daha güçlü olan Miller-Rabin Testi aşağıdaki teoreme dayanmaktadır.

Teorem

Tek bir asal sayı adayı p'nin ayrışımı verildiğinde

$$p' - 1 = 2^u * r$$

r'nin tek sayı olduğu durumlarda, eğer öyle bir tamsayı a bulabilirsek ki...

$$a^r \not\equiv 1 \bmod p' \quad \text{ve} \quad a^{r2^j} \not\equiv p' - 1 \bmod p'$$

Tüm j = {0,1, ..., u-1} için, p' bileşiktir.

Aksi takdirde muhtemelen asal sayıdır.

- Bu teorem bir algoritmaya dönüştürülebilir.

Miller-Rabin Asallık Testi

Algoritma: Miller-Rabin Asallık Testi

Girdi: $p'-1 = 2^{u*r}$ güvenlik parametresi s olan asal aday p'

Çıktı: "p' bileşiktir" veya "p' muhtemelen asaldır"

1. **FOR** $i = 1$ **TO** s
2. rastgele seç $a \varepsilon \{2,3, ..., p'-2\}$
3. $z \equiv a^r \bmod p'$
4. **IF** $z \neq 1$ **AND** $z \neq p'-1$ **THEN**
5. **FOR** $j = 1$ **TO** $u-1$
6. $z \equiv z^2 \bmod p'$
7. **IF** $z = 1$ **THEN**
8. **RETURN** „*p' bileşiktir*“
9. **IF** $z \neq p'-1$ **THEN**
10. **RETURN** „*p'* bileşiktir“
11. **RETURN** „*p' büyük olasılıkla asal sayıdır*“

Bu Bölümün İçeriği

- RSA Kriptosistemi
- Uygulama yönleri
- Büyük Asal Sayıları Bulma
- **Saldırılar ve Karşı Önlemler**
- Öğrenilen Dersler

Saldırılar ve Karşı Önlemler 1/3

- Kriptosistemlere yönelik iki farklı saldırı türü vardır
  - **Analitik saldırılar**, RSA'nın temel probleminin matematiksel yapısını kırmaya çalışır
  - **Uygulama saldırıları,** RSA'nın yazılım veya donanımda gerçekleştirilme biçimindeki doğal zayıflıkları kullanarak gerçek dünyadaki bir uygulamaya saldırmaya çalışır

Saldırılar ve Karşı Önlemler 2/3

RSA genellikle şu analitik saldırı vektörlerine maruz kalır:

- **Matematiksel saldırılar**
  - En bilinen saldırı, $\Phi(n)$ elde etmek için n'nin çarpanlarına ayrılmasıdır.
  - Yeterince büyük bir modül n kullanılarak önlenebilir.
  - Mevcut çarpanlara ayırma rekoru 664 bittir. Bu nedenle, n'nin 1024 ile 3072 bit arasında bir bit uzunluğuna sahip olması önerilir.
- **Protokol saldırıları**
  - RSA'nın esnekliğinden, yani bir şifreli metnin, özel anahtarı bilmeden, ilgili bir düz metne çözülebilen başka bir şifreli metne dönüştürülebilme özelliğinden yararlanır.
  - Uygun dolgu ile önlenebilir.

Saldırılar ve Karşı Önlemler 3/3

- Uygulama saldırıları aşağıdakilerden biri olabilir:
  - **Yan kanal analizi**
    - RSA uygulamasının fiziksel sızıntısından yararlanma (örneğin, güç tüketimi, elektromanyetik yayılım vb.)
  - **Hata enjeksiyon saldırıları**
    - CRT yürütülürken cihazda hatalar oluşturmak, özel anahtarın tamamen sızmasına yol açabilir.

Tüm saldırılar hakkında daha fazla bilgi için Understanding Cryptography kitabının 7.8. bölümüne bakabilirsiniz.

Saldırılar ve Karşı Önlemler 2/2

- RSA genellikle bu analitik saldırı vektörlerine maruz kalır (devamı)
  - **Protokol saldırıları**
    - RSA'nın esnekliğinden yararlanır
    - Uygun dolgu ile önlenebilir
- Uygulama saldırıları aşağıdakilerden biri olabilir
  - **Yan kanal analizi**
    - RSA uygulamasının fiziksel sızıntısından yararlanır (örneğin, güç tüketimi, elektromanyetik yayılım vb.)
  - **Hata enjeksiyon saldırıları**
    - CRT yürütülürken cihazda hatalar oluşturmak, özel anahtarın tamamen sızmasına yol açabilir

Bu Bölümün İçeriği

- RSA Kriptosistemi
- Uygulama yönleri
- Büyük Asal Sayıları Bulma
- Saldırılar ve Karşı Önlemler
- **Öğrenilen Dersler**

Öğrenilen Dersler

- RSA, en yaygın kullanılan açık anahtarlı şifreleme sistemidir.
- RSA, esas olarak anahtar iletimi ve dijital imzalar için kullanılır.
- Açık anahtar e kısa bir tamsayı olabilir, özel anahtar d ise modül n'nin tam uzunluğuna sahip olmalıdır.
- RSA, n'nin çarpanlarına ayrılmasının zor olduğu gerçeğine dayanır.
- Şu anda 1024 bit çarpanlarına ayrılamaz, ancak çarpanlara ayırma alanındaki gelişmeler bunu 10-15 yıl içinde mümkün kılabilir. Bu nedenle, uzun vadeli güvenlik için 2048 veya 3076 bit modüllü RSA kullanılmalıdır.
- RSA'nın basit bir uygulaması çeşitli saldırılara izin verir ve pratikte RSA, dolgu ile birlikte kullanılmalıdır.